

Phishing Minds

Experiência Criativa

Bruno Mazetto

Helen Bonato

Gustavo Delinski

Leticia Fabri

Sumário

<i>Proposta de projeto.....</i>	3
--	----------

Objetivo do Projeto.....	3
Público-alvo	4
Mapa de empatia	4
Fluxo de usuário.....	5
Canvas MVP.....	6
Requisitos Funcionais do Sistema	6
Requisitos Não Funcionais	9
Estórias de Usuário	11
Casos de Uso.....	12
Tabela de Casos de Uso (UC)	12
Diagrama de Casos de Uso	14
Modelagem de Processos - Diagrama BPMN	15
Modelagem de dados.....	16
Dicionário de dados	16
Diagrama de Classes	18
Diagrama de Classes na visão negocial.....	18
Diagrama de classes na visão de implementação	19

Proposta de projeto

Este projeto propõe o desenvolvimento de uma plataforma de **simulação de ataques de phishing**, com o objetivo de avaliar e melhorar o nível de conscientização em segurança da informação dentro das organizações.

A solução permitirá que empresas realizem **campanhas simuladas de phishing** enviadas aos colaboradores, reproduzindo cenários semelhantes aos utilizados em ataques reais, como e-mails falsos, links maliciosos e mensagens enganosas. A partir dessas simulações, será possível identificar comportamentos de risco, medir o nível de vulnerabilidade dos usuários e promover ações de conscientização.

O sistema também disponibilizará **métricas e dashboards analíticos**, permitindo que gestores acompanhem indicadores como taxa de falhas, ranking de setores mais vulneráveis, evolução histórica da segurança e impacto potencial de ataques.

Objetivo do Projeto

Desenvolver uma plataforma que permita **simular ataques de phishing em ambientes corporativos**, possibilitando avaliar o comportamento dos usuários, gerar métricas de segurança e auxiliar organizações na melhoria da conscientização em segurança da informação.

Logo



Público-alvo

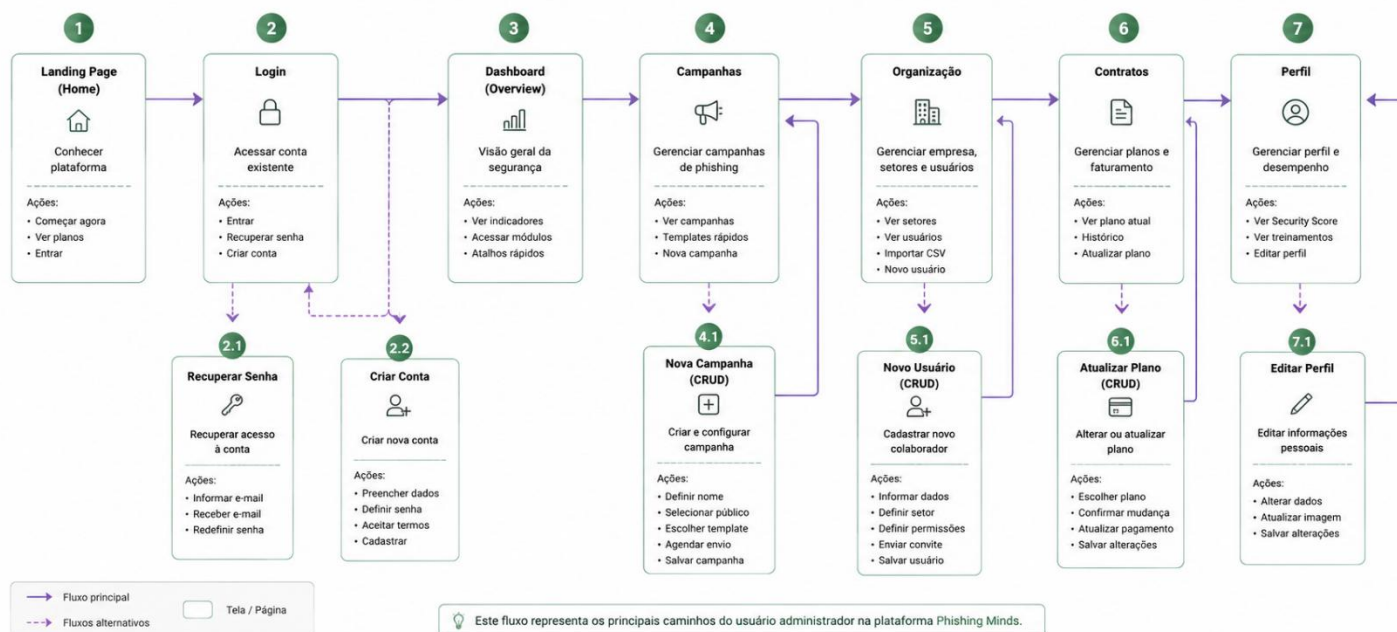
Donos, gestores, coordenadores e diretores de empresas de médio e grande porte de

MAPA DE EMPATIA: GESTOR DE MÉDIA/GRANDE EMPRESA NO BRASIL (Simulador de Phishing)			
O QUE ELE(A) VÊ? - Casos na mídia de vazamento de dados e ransomware. - Empresas concorrentes com projetos inovadores para combater phishing. - Concorrentes investindo em segurança da informação. - Colaboradores usando e-mail arriscados.		O QUE ELE(A) OUVI? - Equipe de TI reclamando da "falta de cuidado" dos usuários. - Consultores de segurança alertando sobre riscos humanos. - Benchmark em segurança e mercado. - Amigos de outros empresários que sofreram ataques.	
O QUE ELE(A) PENSA E SENTE? - Preocupação com a reputação da empresa e multas da LGPD. - Desejo de ter dados claros para tomar decisões. - Sentimento de urgência, apesar de investir em antivírus.	GESTOR DE MÉDIA/GRANDE EMPRESA (Simulador de Phishing)		O QUE ELE(A) FALA E FAZ? - Busca soluções que mostrem ROI e métricas claras. - Aprova orçamentos de segurança (TI, treinamentos). - Define políticas de segurança para a empresa.
DORES (MEDOS E OBSTÁCULOS) - Ser a próxima vítima de um grande ataque. - Custos inesperados de resposta a incidentes. - Perder a confiança dos clientes. - Funcionários que não levam a sério a segurança.		GANHOS (DESEJOS E MEDIDAS DE SUCESSO) - Empresa segura e resiliente a ataques de phishing. - Redução da taxa de falhas nos colaboradores. - Conscientização visível em toda a organização. - Dashboards e relatórios detalhados para apresentar à diretoria.	

qualquer região do Brasil. Entre 30 – 50 anos. Visam a segurança digital da empresa e dos funcionários. Possuem um orçamento mensal mínimo a partir de R\$250,00. Têm como parte de comunicação profissional a utilização de e-mails. Preocupam-se com crescentes casos de prejuízos financeiros e vazamento de informações confidenciais por causa de ataques cibernéticos.

Mapa de empatia

FLUXO DE USUÁRIO – PHISHING MINDS



Fluxo de usuário

Canvas MVP

Requisitos Funcionais do Sistema

PROPOSTA DE VALOR - Plataforma de Simulação de Phishing e Treinamento de Conscientização. - Solução SaaS escalável para empresas de todos os tamanhos. - Criação e execução de campanhas de phishing simulado. - Módulo de aprendizado interativo (microlearning). - Painéis de relatórios detalhados de desempenho. - Automação de campanhas baseada no nível de risco do usuário. - Gestão centralizada e integrada.	SEGMENTOS DE CLIENTES - Empresas (PMEs e grandes corporações). - Organizações em setores de alto risco (Finanças, Saúde). - Departamentos de TI, Segurança da Informação. - Gestores de RH e Conformidade. - Usuários finais (colaboradores).	PROPOSTA DE VALOR - Plataforma de Simulação de Phishing e Treinamento de Conscientização. - Solução SaaS escalável para empresas de todos os tamanhos. - Criação e execução de campanhas de phishing simulado. - Painéis de relatórios detalhados de desempenho. - Automação de campanhas baseada no nível de risco do usuário. - Gestão de feedback contínuo.	CANAIS - Vendas diretas B2B. - Parcerias com MSSPs (Provedores de Serviços de Segurança Gerenciada). - Marketing digital (campanhas de e-mail marketing, LinkedIn Ads, SEO/SEM). - Participação em eventos e conferências de segurança cibernética. - Portal web e demonstrações gratuitas (trial).	FONTES DE RECEITA - Assinaturas recorrentes (modelo SaaS: tiered pricing, e.g., Basic, Pro, Enterprise). - Cobrança por número de usuários ativos. - Serviços profissionais (configuração inicial, treinamento presencial, serviços de consultoria).
	RECURSOS PRINCIPAIS - Plataforma de software e infraestrutura em nuvem (servidores). - Biblioteca de modelos de e-mail de phishing realistas e módulos de treinamento. - Algoritmos de IA/Machine Learning para detecção e personalização. - Equipe de desenvolvimento e especialistas em segurança cibernética. - Marca e propriedade intelectual.	CUSTO & CRONOGRAMA - Fase 1 (0-3 meses): MVP e validação inicial. Custo estimado: R\$ 80k - R\$ 150k. - Fase 2 (3-6 meses): Desenvolvimento completo e lançamento beta. Custo estimado: R\$ 200k - R\$ 350k. - Fase 3 (6-12 meses): Escala e otimização. Custo estimado: R\$ 150k - R\$ 250k. - Total estimado (12 meses): R\$ 430k - R\$ 750k.	ATIVIDADES PRINCIPAIS - Desenvolvimento e manutenção da plataforma SaaS. - Criação de conteúdo de treinamento e e-mails de phishing simulado. - Análise de dados e desenvolvimento de algoritmos de risco. - Vendas e marketing. - Suporte ao cliente.	MÉTRICAS PARA VALIDAR AS HIPÓTESES DE NEGÓCIO - Taxa de conversão de trial para pago. - Taxa de engajamento dos usuários (abertura de e-mails simulados, cliques em treinamentos). - Redução da taxa de cliques em phishing simulado ao longo do tempo. - Churn rate (taxa de cancelamento). - Custo de aquisição de cliente (CAC) vs. Lifetime Value (LTV).
	PARCERIAS PRINCIPAIS - MSSPs e integradores de segurança. - Provedores de infraestrutura em nuvem (e.g., AWS, Azure). - Plataformas de inteligência de ameaças (Threat Intelligence feeds). - Associações e consórcios de segurança cibernética.		ESTRUTURA DE CUSTOS - Desenvolvimento e manutenção do software. - Custos de infraestrutura em nuvem (SaaS hosting). - Salários e benefícios (equipe de desenvolvimento, segurança, vendas). - Custos de marketing e vendas (campanhas, CRM). - Custos de criação de conteúdo.	

ID	Título	Descrição
----	--------	-----------

RF001	Visualizar contrato do serviço	O sistema deve permitir que administradores visualizem os detalhes do contrato da empresa, incluindo plano contratado, número de usuários, validade e funcionalidades habilitadas.
RF002	Cadastro de contrato	O sistema deve permitir o cadastro de novos contratos vinculados a uma empresa.
RF003	Atualização de contrato	Administradores devem poder atualizar informações do contrato, como número de usuários, prazo e escopo.
RF004	Cadastro de empresa	O sistema deve permitir o cadastro de empresas clientes contendo dados como nome, CNPJ, domínio de email e responsável.
RF005	Edição de empresa	Administradores devem poder editar dados cadastrais da empresa.
RF006	Cadastro de setores	O sistema deve permitir cadastrar setores/departamentos dentro da empresa.
RF007	Edição de setores	Administradores devem poder editar nome, descrição e gestor responsável por cada setor.
RF008	Vinculação de usuários a setores	O sistema deve permitir associar usuários aos seus respectivos setores.
RF009	Importação de usuários	O sistema deve permitir importar usuários via planilha ou integração com diretório corporativo.
RF010	Agendamento de simulação de phishing	Administradores devem poder agendar campanhas de phishing simuladas para datas específicas.
RF011	Configuração de público alvo	O sistema deve permitir selecionar quais setores ou usuários participarão da simulação.
RF012	Definição do tipo de phishing	O administrador deve poder escolher o tipo de ataque simulado, como: • email malicioso • link falso • anexo infectado • mensagem interna falsa
RF013	Definição do nível de phishing	O sistema deve permitir definir níveis de dificuldade da simulação, como: • fácil • médio

		• avançado
RF014	Personalização da campanha	Administradores devem poder personalizar: • assunto do email • conteúdo da mensagem • identidade do remetente • layout da mensagem
RF015	Biblioteca de templates de phishing	O sistema deve disponibilizar templates prontos de campanhas de phishing.
RF016	Disparo automático de campanhas	O sistema deve enviar automaticamente os emails de phishing na data e horário agendados.
RF017	Registro de interação do usuário	O sistema deve registrar quando um usuário: • abre o email • clica no link • baixa anexos • insere dados
RF018	Identificação de usuários que caíram no phishing	O sistema deve identificar automaticamente os usuários que interagiram com o ataque simulado.
RF019	Notificação ao gestor	Quando um usuário cair no phishing, o sistema deve enviar um alerta automático ao gestor do setor.
RF020	Registro de ocorrências	O sistema deve manter um histórico de ocorrências de phishing por usuário.
RF021	Controle de reincidência	O sistema deve contar quantas vezes um usuário caiu em simulações.
RF022	Treinamento obrigatório automático	Caso o usuário caia em phishing mais de duas vezes, o sistema deve automaticamente atribuir um treinamento obrigatório de segurança.
RF023	Cálculo de score de segurança por usuário	O sistema deve gerar uma pontuação individual baseada no comportamento do usuário nas simulações.
RF024	Score de segurança por setor	O sistema deve calcular uma pontuação média de segurança para cada setor.
RF025	Ranking de setores	O sistema deve gerar um ranking comparativo entre setores com base na taxa de sucesso nas simulações.

RF026	Comparação histórica de desempenho	O sistema deve permitir visualizar evolução histórica: • por usuário • por setor • geral da empresa
RF027	Simulação de impacto financeiro	O sistema deve estimar o impacto financeiro potencial de ataques reais com base nos resultados das simulações.
RF028	Dashboard gerencial	O sistema deve disponibilizar dashboards para gestores acompanharem: • taxa de falhas • evolução de segurança • ranking de setores
RF029	Painel administrativo avançado	Administradores devem ter acesso a um painel analítico estilo Power BI contendo métricas detalhadas das campanhas.
RF030	Disponibilização de ranking via iframe	O sistema deve gerar um iframe que permita incorporar o ranking de segurança em portais corporativos como intranet.

Requisitos Não Funcionais

Segurança

RNF01 – Autenticação segura

O sistema deve suportar autenticação segura com login e senha, podendo integrar com SSO corporativo.

RNF02 – Controle de acesso baseado em perfil

O sistema deve implementar controle de acesso baseado em perfis:

- administrador
- gestor
- usuário comum

RNF03 – Criptografia de dados

Dados sensíveis devem ser criptografados em trânsito (HTTPS) e em armazenamento.

RNF04 – Proteção de dados pessoais

O sistema deve cumprir requisitos da LGPD para proteção de dados pessoais.

Performance

RNF05 – Tempo de resposta

O sistema deve responder às requisições de interface em até 3 segundos em condições normais.

RNF06 – Processamento de campanhas

O sistema deve suportar disparo de campanhas de phishing para pelo menos 10.000 usuários simultaneamente.

Escalabilidade**RNF07 – Escalabilidade horizontal**

A solução deve permitir escalabilidade para suportar aumento de usuários e empresas.

RNF08 – Multiempresa (multi-tenant)

O sistema deve suportar múltiplas empresas isoladas no mesmo ambiente.

Usabilidade**RNF09 – Interface intuitiva**

A interface do sistema deve ser simples e intuitiva para facilitar uso por gestores.

RNF10 – Design responsivo

O sistema deve ser utilizável em desktop, tablet e dispositivos móveis.

Disponibilidade**RNF11 – Alta disponibilidade**

O sistema deve possuir disponibilidade mínima de 99,5%.

RNF12 – Backup automático

Deve haver backups automáticos periódicos dos dados.

Manutenibilidade**RNF13 – Arquitetura modular**

O sistema deve ser desenvolvido de forma modular para facilitar manutenção e evolução.

RNF14 – Registro de logs

O sistema deve registrar logs de auditoria de todas as ações administrativas.

Confiabilidade

RNF15 – Integridade de dados

O sistema deve garantir integridade das informações registradas nas campanhas.

RNF16 – Monitoramento de falhas

O sistema deve possuir monitoramento automático para detectar falhas.

Compatibilidade**RNF17 – Compatibilidade com navegadores**

O sistema deve funcionar nos principais navegadores modernos (Chrome, Edge, Firefox e Safari).

Integração**RNF18 – Integração com sistemas corporativos**

O sistema deve permitir integração via API com ferramentas corporativas como diretórios de usuários ou plataformas de treinamento.

Estórias de Usuário

ID	História de Usuário
US01	Como administrador da plataforma, quero cadastrar uma empresa para que ela possa utilizar o sistema.
US02	Como administrador da plataforma, quero associar um plano de assinatura a uma empresa para controlar seus recursos.
US03	Como administrador da empresa, quero atualizar os dados da minha empresa para manter as informações corretas.
US04	Como administrador da empresa, quero cadastrar funcionários para incluí-los nas minhas campanhas.
US05	Como administrador da empresa, quero importar funcionários em lote para agilizar o cadastro.
US06	Como administrador da empresa, quero editar dados de funcionários para manter o sistema de campanhas atualizado.
US07	Como administrador da empresa, quero desativar funcionários para evitar envio indevido de campanhas.
US08	Como administrador da empresa, quero criar departamentos de meus setores para organizar os funcionários.
US09	Como administrador da empresa, quero vincular funcionários a seus setores para segmentar campanhas.
US10	Como administrador da empresa, quero criar campanhas de phishing para testar a segurança dos funcionários.

US11	Como administrador da empresa, quero definir o público-alvo da campanha para direcionar os testes.
US12	Como administrador da empresa, quero agendar campanhas para automatizar o envio.
US13	Como administrador da empresa, quero editar campanhas antes do envio para atingir o público-alvo corretamente.
US14	Como administrador da empresa, quero visualizar o status da campanha para acompanhar seu andamento.
US15	Como administrador da empresa, quero criar templates de e-mail para reutilizar em campanhas.
US16	Como administrador da empresa, quero usar variáveis dinâmicas (ex: nome, empresa) para personalizar os e-mails.
US17	Como sistema, quero registrar quando um e-mail é aberto para medir engajamento.
US18	Como sistema, quero registrar quando um link é clicado para identificar vulnerabilidades.
US19	Como sistema, quero registrar quando credenciais são inseridas para medir níveis de risco.
US20	Como sistema, quero registrar quando o phishing é reportado para identificar usuários conscientes.
US21	Como administrador da empresa, quero visualizar métricas de campanhas para analisar resultados.
US22	Como administrador da empresa, quero visualizar ranking de usuários e departamentos para identificar riscos.
US23	Como administrador da empresa, quero identificar usuários mais vulneráveis para direcionar ações.
US24	Como administrador da empresa, quero tomar decisões com base nos dados para melhorar a segurança.

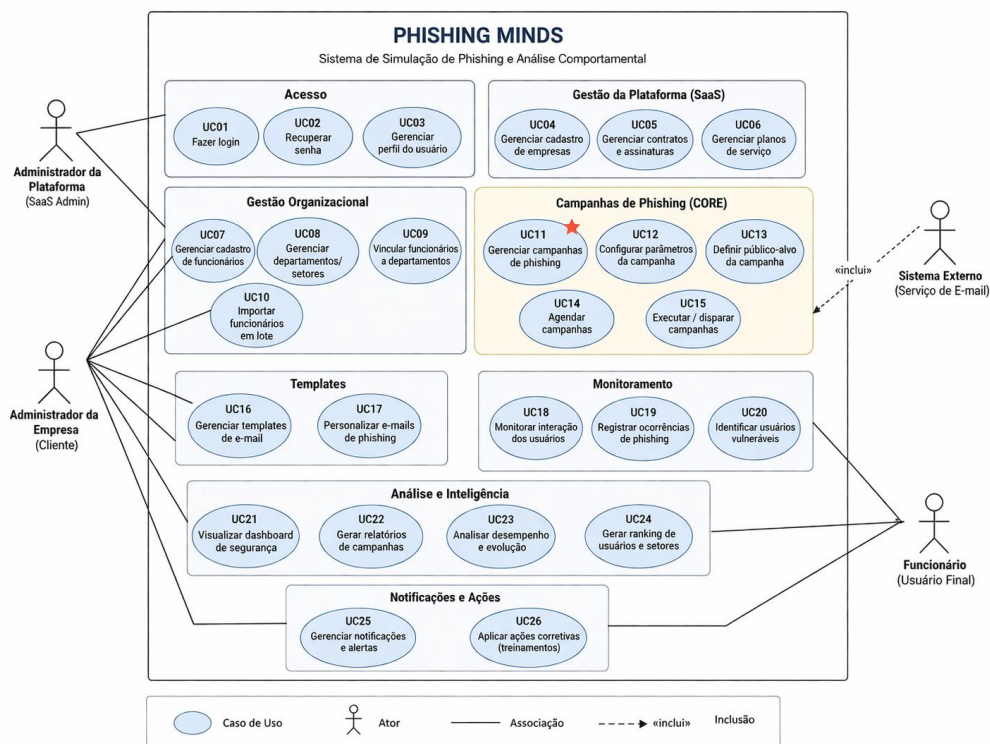
Casos de Uso

Tabela de Casos de Uso (UC)

	Caso de Uso
<u>UC01</u>	Fazer login
<u>UC02</u>	Recuperar senha
<u>UC03</u>	Gerenciar perfil do usuário
<u>UC04</u>	Gerenciar cadastro de empresas
<u>UC05</u>	Gerenciar contratos e assinaturas

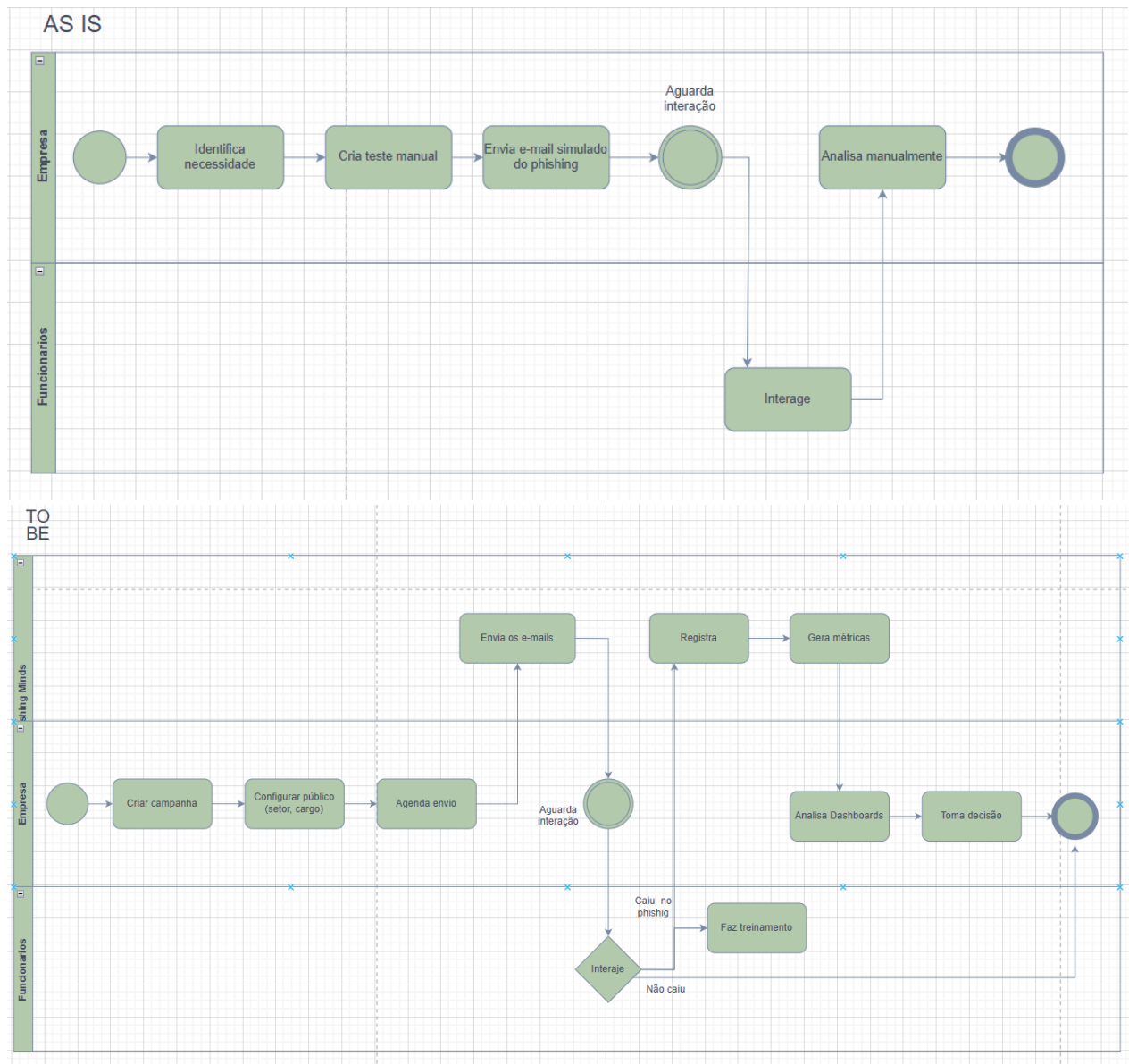
<u>UC06</u>	Gerenciar planos de serviço
<u>UC07</u>	Gerenciar cadastro de funcionários
<u>UC08</u>	Gerenciar departamentos / setores
<u>UC09</u>	Vincular funcionários a departamentos
<u>UC10</u>	Gerenciar campanhas de phishing
<u>UC11</u>	Configurar parâmetros da campanha
<u>UC12</u>	Definir público-alvo da campanha
<u>UC13</u>	Agendar campanhas
<u>UC14</u>	Executar/disparar campanhas
<u>UC15</u>	Gerenciar templates de e-mail
<u>UC16</u>	Personalizar e-mails de phishing
<u>UC17</u>	Monitorar interação dos usuários
<u>UC18</u>	Registrar ocorrências de phishing
<u>UC19</u>	Identificar usuários vulneráveis
<u>UC20</u>	Visualizar dashboard de segurança
<u>UC21</u>	Gerar relatórios de campanhas
<u>UC22</u>	Analisar desempenho e evolução
<u>UC23</u>	Gerar ranking de usuários e setores
<u>UC24</u>	Gerenciar notificações e alertas
<u>UC25</u>	Aplicar ações corretivas (treinamentos)

Diagrama de Casos de Uso

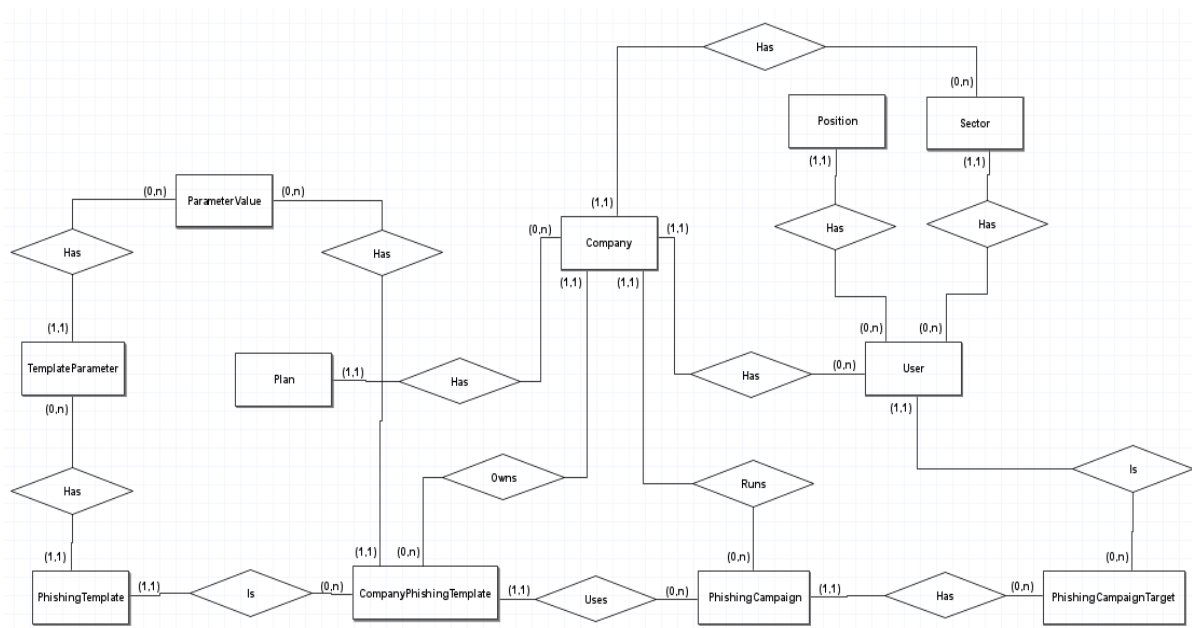


Modelagem de Processos - Diagrama BPMN

1. Business Process Model and Notation



Modelagem de dados



Dicionário de dados

Tabela: Empresa

Campo	Tipo	Descrição
IdEmpresa	INT (PK)	Identificador único da empresa
IdPlano	INT (FK)	Plano contratado pela empresa
Nm_Empresa	VARCHAR(200)	Nome da empresa
Nm_Dono	VARCHAR(200)	Nome do proprietário ou responsável
Mail	VARCHAR(200)	E-mail principal da empresa
CNPJ	VARCHAR(20)	Cadastro Nacional da Pessoa Jurídica
Dt_Cadastro	DATETIME	Data de cadastro da empresa
Dt_Contratacao	DATETIME	Data de contratação do serviço
Dt_FimContrato	DATETIME	Data de término do contrato
Ativo	BOOLEAN	Indica se a empresa está ativa
Senha	VARCHAR(255)	Senha de acesso da empresa

Tabela: Plano

Campo	Tipo	Descrição
IdPlano	INT (PK)	Identificador do plano
Nm_Plano	VARCHAR(100)	Nome do plano
Desc_Plano	TEXT	Descrição do plano
Temp_Plano	INT	Duração do plano em meses
Value_Plano	DECIMAL(10,2)	Valor do plano
MaxUsers	INT	Número máximo de usuários
MaxCampaigns	INT	Número máximo de campanhas

Tabela: Cargo

Campo	Tipo	Descrição
IdCargo	INT (PK)	Identificador do cargo
Nm_Cargo	VARCHAR(100)	Nome do cargo

Tabela: Setor

Campo	Tipo	Descrição
IdSetor	INT (PK)	Identificador do setor
IdEmpresa	INT (FK)	Empresa à qual o setor pertence
Nm_Setor	VARCHAR(100)	Nome do setor
IdGestor	INT (FK)	Usuário responsável pela gestão do setor

Tabela: Pessoa

Campo	Tipo	Descrição
IdUser	INT (PK)	Identificador do usuário
IdEmpresa	INT (FK)	Empresa à qual pertence
IdSetor	INT (FK)	Setor do usuário
IdCargo	INT (FK)	Cargo do usuário
Nome	VARCHAR(200)	Nome completo
Email	VARCHAR(200)	E-mail corporativo
Senha	VARCHAR(200)	Senha de acesso
Ativo	BOOLEAN	Situação do usuário
Dt_Cadastro	DATETIME	Data de cadastro
UltimoLogin	DATETIME	Data do último acesso
PhishingScore	INT	Pontuação de segurança do usuário

Tabela: Treinamento

Campo	Tipo	Descrição
IdTreinamento	INT (PK)	Identificador do treinamento
IdUser	INT (FK)	Usuário vinculado ao treinamento
Aprovado	BIT	Indica aprovação no treinamento
DtConclusao	DATETIME	Data de conclusão do treinamento

Diagrama de Classes

Diagrama de Classes na visão negocial

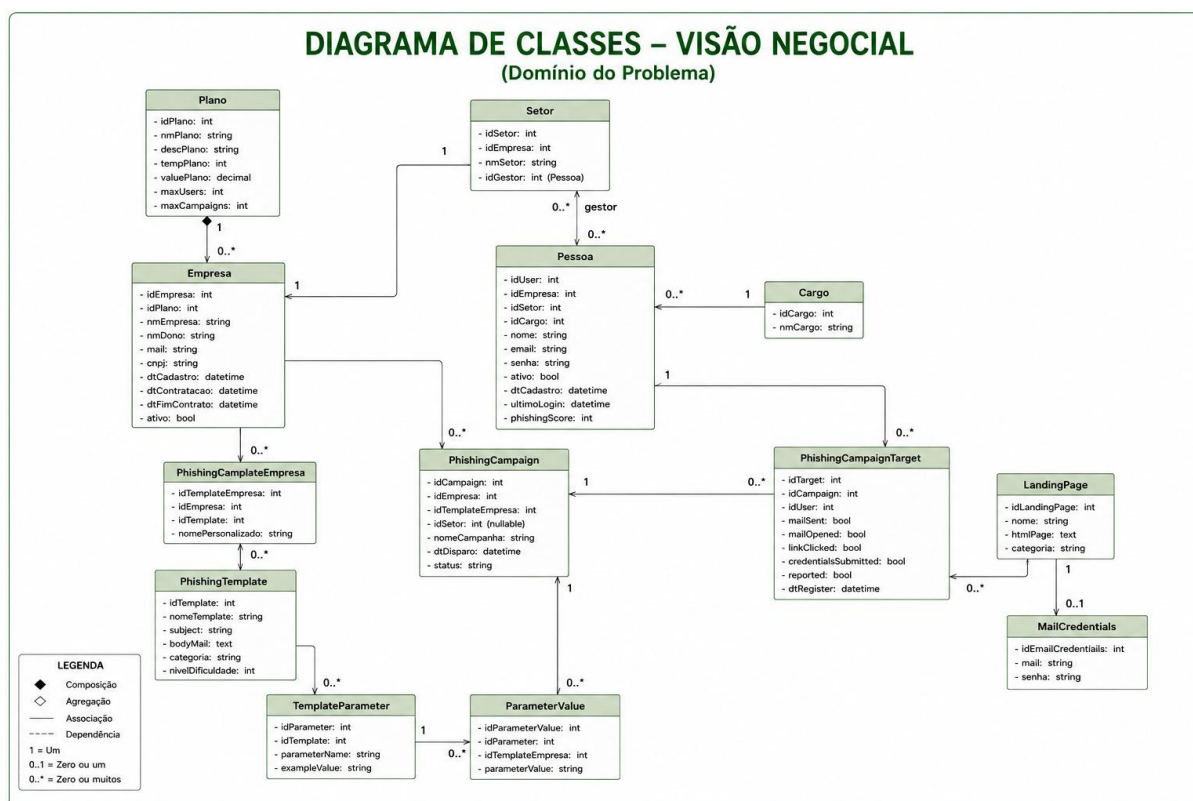


Diagrama de classes na visão de implementação

DIAGRAMA DE CLASSES – VISÃO DE IMPLEMENTAÇÃO

(Arquitetura MVC – ASP.NET Web Forms / C#)

